

NARRATIVA EXPLICATIVA: EL VIAJE DE LA ENCUESTA CRA-CYBER

Una Historia de Madurez, Números y Algunas Sorpresas (Probables)

Tono: Irónico, literario, profundamente técnico pero ameno

Audiencia: CISOs, responsables de seguridad, inversores en ciberseguridad

Propósito: Humanizar la evaluación cuantitativa de ciberseguridad

PRÓLOGO: LOS NÚMEROS NO MIENTEN, PERO TAMPOCO CUENTAN TODA LA HISTORIA

Existe una ironía de proporciones cómicas en la ciberseguridad: hemos construido sistemas tan complejos para proteger datos, que medir si esos sistemas funcionan se ha convertido en una tarea tan complicada como la protección misma.

Usted dirige una organización. Cada año, asigna presupuesto a ciberseguridad. ¿Cuánto? Una cifra que sacó de un benchmark, de lo que gastó el competidor, o simplemente de lo que sobra en el presupuesto de IT después de financiar "cosas realmente importantes" como nuevos servidores que nadie pidió.

Pero aquí viene la pregunta incómoda: **¿Realmente sabe cuánto cuesta mantener su organización protegida?**

No nos referimos al presupuesto anual. Nos referimos al *coste real estructural* — el de todos esos profesionales en seguridad que monitorean, parquean vulnerabilidades, investigan incidentes, capacitan personal. Esos costes que están ahí, invisibles, como el aire que respira: siempre presentes, raramente contabilizados.

Eso es lo que CAsPeA intenta revelar. Y es lo que CRA-Cyber intenta medir.

ACTO 1: EL PROBLEMA — POR QUÉ UNA ENCUESTA INTEGRAL

Escena 1: El CISO y el CFO

Escenario típico, una sala de juntas, 14:00h.

CISO: "Necesitamos €200.000 adicionales para fortalecer detección de amenazas. Nuestro SIEM no tiene capacidad suficiente."

CFO: "¿Por qué? ¿Qué riesgos estamos asumiendo? ¿Cuál es el ROI?"

CISO: "Bueno... si un breach nos cuesta €500.000 en promedio, y podemos reducir ataques exitosos en un 15%... el ROI es... aproximadamente bueno."

CFO: "¿Aproximadamente?"

CISO: "Muy aproximadamente."

Fin de escena.

Esta conversación ocurre en organizaciones españolas cada semana. Y el resultado es predecible: o se aprueba el presupuesto por fe, o se rechaza por falta de justificación. Rara vez hay una respuesta cuantificada, defendible, auditada.

Escena 2: La Evaluación Regulatoria

Llega NIS2 (Q1 2026). Un auditor externo llama:

Auditor: "¿Dispone de recursos humanos suficientes en ciberseguridad para cumplir NIS2?"

Responsable AAPP: "Sí, tenemos... dos especialistas a tiempo completo."

Auditor: "¿Para una organización de 1.200 empleados?"

Responsable: "...sí."

Auditor: "Según estándares de resiliencia digital, deberían tener 5-7. Esto es un incumplimiento."

Responsable: "¿Cómo lo supo?"

Auditor: "Porque existe una metodología llamada CAsPeA que permite cuantificar exactamente eso."

Responsable: "¿CAsPeA?"

Auditor: "Sí. Debería haber usado la encuesta CRA-Cyber hace dos años."

Fin de escena.

ACTO 2: LA SOLUCIÓN — ¿QUÉ ES CRA-CYBER?

La Encuesta como Instrumento de Inteligencia

CRA-Cyber no es una encuesta normal. Normalmente, las encuestas miden opiniones ("¿Qué tan seguro se siente?") o hechos aislados ("¿Tiene un SIEM?").

CRA-Cyber es un **instrumento de inteligencia operacional**. Mide:

1. Capacidades organizacionales — ¿Qué controles están implementados?
2. Procesos y madurez — ¿Cómo están organizados esos controles?
3. Recursos de personal — ¿Quién mantiene esos controles, y cuánto cuesta?
4. Efectividad de controles — ¿Los controles funcionan realmente? (MTTD, MTTR)
5. Impacto en riesgo — ¿Cuántos incidentes se evitaban?

Estructura de Seis Pilares

Pilar 1: Caracterización Organizacional

¿Por qué importa?

No es lo mismo evaluar ciberseguridad en:

- Un banco de 5.000 empleados procesando transacciones críticas (24/7, regulación DORA, PCI-DSS)
- Una PYME de 80 empleados vendiendo ropa online (horario comercial, GDPR básico)

Por eso la encuesta comienza preguntando contexto: sector, tamaño, criticidad de datos, infraestructura, regulación aplicable.

Metáfora: Así como un cardiólogo pregunta edad, peso y antecedentes antes de evaluar un corazón, un auditor de ciberseguridad debe entender el contexto antes de evaluar madurez.

Pilar 2: Gestión de Vulnerabilidades

El núcleo de la defensa preventiva.

Aquí medimos:

- ¿Realiza escaneo de vulnerabilidades? (Sí/No/Cadencia)
- ¿Cuánto de su infraestructura está cubierta? (% de cada tipo de activo)
- ¿Cómo prioriza vulnerabilidades? (¿Usa CVSS? ¿EPSS? ¿Contexto empresarial?)
- ¿Cuál es su MTTR (Mean Time To Remediate)? (SLA vs realidad)
- ¿Qué hace con vulnerabilidades sin parche? (Controles compensatorios, aceptación de riesgo)

Por qué es crucial:

Una vulnerabilidad identificada pero no remediada es como un incendio que ve venir pero no apaga. Es intelectualmente útil, pero prácticamente inútil.

Incisión irónica: El 78% de organizaciones que sufrieron breach tenían la vulnerabilidad explotada identificada *hace meses* en su propio escaneo de vulnerabilidades. Simplemente nunca la remediaron.

Pilar 3: Pruebas de Penetración

La perspectiva del atacante.

A diferencia de escaneo de vulnerabilidades (que identifica *potenciales* debilidades), pentesting intenta *explotarlas realmente*.

Preguntamos:

- ¿Con qué frecuencia hace pentesting? (Anual, semestral, trimestral, continuo)
- ¿Quién lo hace? (Personal interno, consultor externo, red team híbrido)
- ¿Qué alcance tiene? (Red, web, física, social engineering, OT)
- ¿Cuál es el modelo de conocimiento? (Black-box, gray-box, white-box)
- ¿Cuál es la madurez del programa? (Nivel 1-5, desde ad hoc hasta optimizado)
- ¿Cuánto tiempo desde hallazgo hasta remediación validada?

Profundidad metafórica: Si escaneo de vulnerabilidades es una radiografía, pentesting es una exploración quirúrgica. Uno te dice "hay algo raro aquí", el otro te muestra exactamente dónde está y cómo llegar.

Pilar 4: Gestión de Información y Eventos de Seguridad (SIEM)

La voz de vigilante 24/7.

Un SIEM es como tener un guardia de seguridad observando 1 millón de eventos por segundo. La pregunta no es si tienes SIEM, sino:

- ¿Qué fuentes de datos están integradas? (¿Incluye cloud, endpoints, OT?)
- ¿Cuál es la sofisticación de detección? (¿Firmas simples o IA?)
- ¿Cómo se integra con respuesta? (¿Manual, SOAR automatizado?)
- ¿Cuál es su MTTD? (Mean Time To Detect — métrica CRÍTICA)
- ¿Cuál es su MTTR? (Mean Time To Respond — métrica CRÍTICA)
- ¿Cuál es su tasa de verdaderos positivos? (¿80% de alertas son reales, o solo 20%?)

Realidad incómoda: La mayoría de CISOs no conocen su MTTD real. Dicen "aproximadamente dos días" cuando la realidad es "nunca lo hemos medido formalmente". CRA-Cyber obliga a medir.

Pilar 5: Capacitación en Seguridad

El factor más infravaluado y subestimado de la seguridad.

Según estudios de NIST, entre 80-90% de incidentes se deben a error humano. Sin embargo, en presupuestos de seguridad, capacitación frecuentemente recibe <5% del gasto.

Preguntamos:

- ¿Existe programa de capacitación formalizado? (¿O es un video anual obligatorio?)
- ¿Es genérico o diferenciado por rol? (Todos iguales, o DevSecOps aprende desarrollo seguro)
- ¿Usa simulaciones de phishing como métrica? (¿Cuál es su tasa de click/report?)
- ¿Mide cambio de comportamiento? (¿O solo "completó el curso"?)
- ¿Cuál es el presupuesto dedicado? (Como % del total seguridad)

Paradoja detectada: Las organizaciones que MENOS presupuesto dedican a capacitación son las que más sufren incidentes por error humano. Luego gastan 10x remediando lo que €10K en capacitación hubiera prevenido.

Pilar 6: Indicadores de Madurez y ROI

Donde números y dinero convergen.

Aquí cerramos el círculo:

- Evaluación NIST CSF: Madurez por función (Govern, Identify, Protect, Detect, Respond, Recover)
- Histórico de incidentes: ¿Cuántos incidentes, cuál fue el coste, ha mejorado la tendencia?
- CAsPeA: ¿Cuánto cuesta realmente el personal de seguridad? (Desglose detallado)
- ROI cuantificado: Beneficio neto / inversión = % retorno

Epifanía esperada: "Ah, gastar €500K en seguridad evitó €1.2M en incidentes. El ROI es 140%. Ahora apruebo los €600K del año que viene."

ACTO 3: EL ANÁLISIS — CÓMO SE INTERPRETAN LOS NÚMEROS

De Datos Crudos a Inteligencia

Cuando cierra la encuesta y descarga 150 respuestas de excel...

Estadística Descriptiva: El "¿Quién Soy Comparado con Otros?"

Primer paso: compararse. No en términos absolutos ("mi MTTD es 120 minutos"), sino en contexto ("mi MTTD es 120 minutos, pero la mediana de mi sector es 90 minutos").

Ejemplo real esperado:

MTTD (Mean Time To Detect)

Sector Financiero (32 organizaciones):

Mediana: 87 minutos

IQR (50% central): 45-140 minutos

Mi organización: 120 minutos

Percentil: 62 (mejor que el 62% del sector)

Interpretación: "Estamos levemente por debajo del promedio, pero no de forma crítica. El rango es amplio (45-140 min), sugiriendo heterogeneidad en madurez SIEM."

Análisis de Brechas: El "¿Debo Mejorar?"

Segundo paso: comparar estado actual vs objetivo.

Ejemplo real esperado:

Cobertura NIST CSF: Función DETECT

Estado actual: 48%

Objetivo sector financiero (Tier 3): 78%

Brecha: 30 puntos porcentuales

En términos monetarios (CAsPeA):

Coste actual DETECT: €120.000 (27% de presupuesto total)

Coste incremental para Tier 3: +€85.000 (adicionales 5 FTE especialistas SIEM)

Tiempo estimado: 18 meses

Benchmarking: El "¿Quién es Mi Par?"

Búsqueda de "similar a mí":

- Mismo sector (Ej: Financiero)
- Similar tamaño (250-500 empleados)
- Similar criticidad (datos sensibles, regulación DORA)

Resultado: "Encontramos 8 organizaciones financieras de 250-500 empleados bajo DORA"

Luego: "Estos 8 tienen MTTR mediana de 92 minutos. Ustedes: 120. Gastaban €520K en seguridad mediana. Ustedes: €480K. Recomendación: aumentar presupuesto en €60K, enfocado en automatización SIEM → esperar MTTR ~90min en 12 meses."

Análisis de ROI: El "¿Me Conviene?"

Cálculo esperado:

Inversión actual anual: €480.000
Incidentes anuales actuales: 3.2 (promedio 5 años)
Coste promedio incidente: €240.000
Pérdida anual sin controles: $3.2 \times €240K = €768K$

Con controles actuales:
Incidentes reducidos a: 1.1/año
Pérdida residual: $1.1 \times €240K = €264K$
Pérdida evitada: $€768K - €264K = €504K$

Beneficio neto = Pérdida evitada - Inversión = $€504K - €480K = €24K$
ROI = $€24K / €480K = 5\%$ anual

Interpretación: "ROI bajo (5%) sugiere falta de optimización. Incremento de €60K en automatización SIEM podría:
- Reducir incidentes a 0.6/año (+€120K beneficio)
- ROI total: $€120K / €540K = 22\%$ (MUCHO MEJOR)"

ACTO 4: LOS HALLAZGOS ESPERADOS — SORPRESAS PROBABLES

Hallazgo 1: El Abismo de la Remediación

Predicción: La mayoría de organizaciones identifica vulnerabilidades, pero tarda 3-6 meses en remediar críticas.

Reflexión: ¿Por qué? No porque no sepan *cómo*, sino porque:

- Personal IT dedicado a parches < personal IT dedicado a nuevos proyectos
- Cambios de código/configuración requieren testing que ralentiza
- Procesos de control de cambios demasiado burocrático

Solución que emerge del análisis:

Benchmark muestra: Las 20% de organizaciones con MTTR < 30 días tienen:
- Automatización de testing (CI/CD)
- Cambios pequeños y frecuentes (no batch mensuales)
- Roles dedicados a remediación (no "también hace esto")
- Inversión: €120-150K adicionales en tooling + 2 FTE

ROI: 6 meses (evitan 2-3 breaches medianos)

Hallazgo 2: La Matrícula Oculta de Talento

Predicción: Personal IT compartido entre proyectos y seguridad representa 40-60% de "costo real" de seguridad, pero no está presupuestado.

Reflexión: Un admin de sistemas dedica 20% tiempo a seguridad: patches, config, cambios. Eso son ~400h/año × €25/h = €10K. Pero ese coste NO aparece en presupuesto seguridad (aparece bajo "infraestructura").

Sorpresa del análisis: Cuando se agrega personal compartido:

Presupuesto declarado "seguridad": €400K
Personal dedicado: €300K

Personal compartido (oculto):
- 8 admins × 20% tiempo = 1.6 FTE = €70K
- 4 developers × 15% tiempo = 0.6 FTE = €40K
Total oculto: €110K

Coste REAL seguridad: €400K + €110K = €510K
(27% más del declarado)

Implicación: Cuando auditor dice "necesita 5 FTE dedicadas a seguridad", organización responde "tenemos 3 dedicadas + personal compartido". Auditor replica: "El personal compartido NO cuenta, porque está también asignado a otros. Necesita 5 DEDICADAS".

CRA-Cyber fuerza contabilidad honesta.

Hallazgo 3: La Brecha Generacional en Madurez

Predicción: Organizaciones financieras y sanitarias grandes (Tier 3-4) coexisten con PYMES en Tier 1.

Distribución esperada de IMG (Índice Madurez General):

Financiero grande:	IMG 65-75 (Tier 3-4)
Sanitario grande:	IMG 52-62 (Tier 2-3)
AAPP grande:	IMG 45-55 (Tier 2)
Energía (privatizada):	IMG 60-70 (Tier 3)
TIC medianas:	IMG 55-65 (Tier 2-3)
Manufactura:	IMG 30-45 (Tier 1-2)
PYMES:	IMG 15-35 (Tier 1)

Reflexión: Las PYMES están 2-3 Tiers por debajo. ¿Por qué?

- Presupuestos 10-50x menores
- Personal IT multidisciplinario (un IT hace de todo)
- Regulación menos exigente
- Amenazas percibidas como "menos relevantes" (error)

Recomendación de política: Programas de apoyo público para PYMES (subsidios formativos, asesoría, herramientas de bajo coste) podrían:

- Elevar IMG promedio PYMES de 20 a 35 (75% mejora)
- Invertir €50M ahora para evitar €500M en breaches en 5 años

ACTO 5: REFLEXIÓN FINAL — LA HISTORIA QUE CUENTAN LOS NÚMEROS

Por Qué Importa Esta Encuesta

CRA-Cyber y CASPeA no son ejercicios académicos. Son herramientas que **convierten opiniones vagas en hechos cuantificables**.

Antes de CRA-Cyber:

CISO: "Necesitamos más inversión en ciberseguridad."

CF0: "¿Por qué?"

CISO: "Porque... sí. Porque el NIST lo recomienda. Porque tuvimos un incidente."

CF0: "No me convences."

Resultado: Se aprueba presupuesto mínimo. Sigue siendo insuficiente.

Después de CRA-Cyber:

CISO: "Nuestro IMG es 48 (Tier 2). El benchmarking de nuestro sector (financiero) es 62 (Tier 3). Para alcanzar Tier 3, necesitamos €380K adicionales en personal. Con eso, reduciremos MTTD de 120 a 60 minutos, evitando ~€600K en incidentes anuales. ROI: 158%. Payback period: 7.6 meses."

CF0: "¿Puedo ver el análisis detallado?"

CISO: "Aquí está. Incluye benchmarking de 32 bancos, análisis de sensibilidad, proyección 3 años."

CF0: "Se aprueba €400K (con contingencia). Quiero reporte trimestral sobre IMG."

Resultado: Presupuesto bien justificado. Responsabilidad clara. Mejora continua.

EPÍLOGO: UNA INVITACIÓN

Esta narrativa termina aquí, pero la **suya está por escribirse**.

Cuando complete la encuesta CRA-Cyber, cuando vea sus números reflejados en benchmarks, cuando calcule el ROI de su inversión en ciberseguridad... entonces sabrá exactamente dónde está.

Y sabrá exactamente adónde debe ir.

Los números no mienten. Pero ahora, tampoco esconden la historia.

FIN

"La seguridad es como la salud: no la aprecias hasta que la pierdes. CRA-Cyber te ayuda a no perderla."

Documento narrativo complementario a Encuesta Integral CRA-Cyber v2.1